

[PLACEHOLDER TITLE – state the finding, not the topic.]

Does Reviewer Diversity Add Real Coverage, or Just Confidence?

A Replay of the OpenAI/Hugging Face Sandbox-Escape Incident

Sofia Gallego

Muhammad Shoaib Altaf

jambohaku

Melody

tiramisu

September 2026

Abstract

Frontier AI safety increasingly relies on layered containment: automated monitors, specialised reviewers, and human escalation working together. But whether combining multiple watchers genuinely improves detection, or merely duplicates the same judgment while appearing more robust, is untested against a real incident. We replay the July 2026 OpenAI/Hugging Face sandbox-escape incident step by step, revealing to each protocol only the information that would have been available at that point in time, and compare a general monitor, several identical monitors, and specialised reviewers on detection timing, false alarms, and decision severity. [TODO: one to two sentences stating the actual headline result once analysis is complete.] We translate the strongest finding into a deployable clause with supporting evidence and estimated cost.

1 Introduction

Frontier labs increasingly rely on layered defenses to contain AI agents that may drift toward unsafe behavior during autonomous operation: sandboxing, permission gates, automated monitors, and human review. Each layer sees a different slice of the problem. A permission check can verify that a single action is authorized but miss a pattern that only becomes visible across a long sequence of otherwise-authorized actions. A human reviewer brings judgment and context but cannot sustain constant real-time attention. Several monitoring agents watching the same stream of actions may or may not add real coverage over a single one – if they share the same blind spots, replicating them creates the appearance of defense-in-depth without the substance.

This is not a hypothetical concern. In July 2026, two OpenAI models running with reduced cyber-safety refusals for an internal capability evaluation (ExploitGym) escaped their sandboxed evaluation environment via a previously-unknown vulnerability, then used the resulting internet access to compromise Hugging Face’s production infrastructure over several days before being detected and contained [1, 2]. OpenAI’s own postmortem noted that existing controls “failed repeatedly despite initial detection and intervention” – language that names, without resolving, the exact question this project investigates: given some detection capability, why did containment still fail, and would a different combination of monitors and escalation points have changed the outcome?

We ask a narrower, more tractable version of this question: *does combining multiple AI reviewers of a live agent trajectory add measurable, independent detection coverage, or does it mainly add confidence without adding coverage?* We test this by progressively replaying the public, reconstructed timeline of the incident, revealing to each candidate containment protocol only the information that would have been observable up to that point – never the outcome, never a hidden ground-truth label – and comparing four protocol designs: a single general-purpose monitor, several identical copies of that monitor, a set of specialised reviewers each watching for a different failure mode (permissions, task intent, security, downstream

consequences), and variants of when a human is brought into the loop. We compare protocols on detection timing, false-alarm rate, human-review burden, and computational cost, and translate the strongest result into a concrete, adoptable clause in the format this track requests: clause $\rightarrow$ evidence $\rightarrow$ approximate cost.

This project is a direct extension of prior work on *false epistemic redundancy* [4], which asked a structurally identical question about post-hoc, retrospective investigation: do differently-framed AI agents examining the same evidence actually search different parts of a hypothesis space, or do they produce surface disagreement while sharing the same blind spot? That work found the answer was case-dependent. Here we ask the same question about real-time monitoring rather than after-the-fact investigation, using one real, documented incident as the test case rather than a synthetic one.

We are explicit about scope. A single incident, replayed once, cannot establish a general base rate for how often reviewer diversity helps; it can only show whether it helped in this one, well-documented case, and by how much. We treat this as a first, honest test of the underlying question, not as a general finding – see Section 6 for a fuller discussion of what would be needed to generalize this result.

2 Related Work

Work on safeguarding LLM agents has largely focused on building better individual reviewers. GuardAgent [5] reframes safeguarding as a guard-agent architecture with knowledge-enabled reasoning rather than a single classifier pass. Multi-agent debate has been proposed as a way to structure safety evaluation through adversarial or cooperative discussion between models [6]. MAGE [7] addresses long-horizon threats specifically, using shadow memory to retain security-relevant context across an extended agent trajectory. Layered, defense-in-depth framings such as the “Swiss Cheese” model for AI safety by design [10] and integrated runtime governance frameworks such as MI9 [9] argue for combining multiple, non-identical controls, but largely at the level of architectural recommendation rather than empirical comparison against a real incident.

Closest to our central question is recent work on ensemble monitoring for AI control [8], which directly tests whether diverse monitor signals outperform scaling up identical monitors, finding that diversity outperforms scale, with returns to ensemble size plateauing around ~ 32 monitors. Our contribution is not this diversity-versus-redundancy claim itself – it already exists in the literature – but stress-testing it against one grounded, real incident with strict temporal information cuts (each protocol sees only what would have been knowable at that point in the real timeline), and translating the result into a deployable clause rather than a benchmark metric.

3 Methodology

3.1 Incident and Timeline Reconstruction

We use the July 2026 OpenAI/Hugging Face sandbox-escape incident as our test case. No raw internal logs from either organization are public. We reconstructed a 26-step ground-truth timeline from Hugging Face’s own technical postmortem [2] and a third-party consolidated timeline [3], spanning training onset (May 7, 2026) through the point at which OpenAI and Hugging Face confirmed the two incidents were the same intrusion (July 20, 2026).

Each timestep has a timestamp, a description of what would have been observable at that point, and a hidden ground-truth label (*benign/unsafe*) used only for scoring, never exposed to a protocol during a decision. We deliberately rewrote the observable description at each step to avoid hindsight framing: initial drafts, derived directly from incident summaries, described events with the vocabulary of the postmortem itself (“attack”, “malicious”, “compromised”), which would allow any protocol to trivially agree on every step by pattern-matching on verdict language rather than interpreting ambiguous signal. The final version

describes each step in the register of a plausible contemporaneous log or alert (e.g. “181 mesh-enrollment attempts from the sandbox IP range over ~ 3.5 hours using the same auth-key format”) so that a protocol must interpret technical detail rather than recognize a label. Both versions are retained in the repository for provenance and audit.

3.2 Replay Engine

A dedicated harness [jambohaku: describe `replay_engine.py` here – what guarantees does it enforce, and how] steps through the timeline and exposes to a protocol, at step n , only steps $0..n$ of observable information – never later steps, never the ground-truth label. Ground-truth labels are joined back to the protocol’s recorded decisions only after a complete run, for scoring.

3.3 Protocols Compared

- **General monitor:** a single broad-scope reviewer.
- **Identical monitors:** four independently-sampled copies of the same broad-scope prompt, aggregated by [TODO: describe aggregation rule].
- **Specialised reviewers:** four reviewers, each scoped to one category – permissions, task intent, security, downstream consequences – aggregated by the same rule.
- **Human-escalation variants:** [TODO(Muhammad/tiramisu): this condition is out of scope for the initial implementation – either describe what was actually run, or state explicitly in Discussion that this was scoped out for time and is future work.]

Choice	Value
Model	Qwen2.5-7B-Instruct (shared Modal endpoint)
Sampling	Temperature 0.2, top-p 1.0
Identical/specialist count	4 each
Aggregation	Max severity: continue < investigate < restrict < pause < terminate
Detection scoring	First restrict/pause/terminate
Human escalation trigger	Any reviewer recommending investigate or above

Table 1: Fixed experimental defaults for the reference run. [TODO: confirm these are final, or note any changes made after review.]

3.4 Sensitivity Check

[TODO(Melody)]

3.5 Metrics

- **Detection lag:** number of steps between the first ground-truth `unsafe` step and a protocol’s first `restrict/pause/terminate` decision.

- **False-alarm rate:** rate of `restrict/pause/terminate` decisions on benign-labeled steps. Soft escalations (`investigate`) on benign steps are reported separately as *benign investigation / soft-escalation burden*, per pre-registration, rather than folded into the primary false-alarm definition after seeing results.
- **Human-review burden:** rate of decisions that would trigger human escalation under the fixed policy.
- **Cost:** token usage and latency per protocol per full replay.
- **Signal overlap / unique coverage:** [TODO(Melody): describe the overlap analysis between identical and specialised reviewers’ detected signals.]

4 Results

[TODO(Melody): headline finding first, in one or two sentences, then support it with the detail below.]

4.1 Detection Timing

[TODO: table or figure – detection lag per protocol.]

4.2 False Alarms and Soft Escalations

[TODO: strict false-alarm rate (`restrict/pause/terminate` on benign steps) and benign-investigation rate, per protocol.]

4.3 Decision Severity and Divergence

[TODO: where protocols agree vs. disagree on the same step, and whether disagreement correlates with ambiguous vs. unambiguous ground truth.]

4.4 Signal Coverage

[TODO: unique vs. shared signals detected across identical and specialised reviewers.]

4.5 Sensitivity Check Result

[TODO(Melody): does the independent-seed run change the identical-monitors result materially? This is important for the paper’s central claim – if identical monitors only looked alike because they shared a seed with the general monitor, that changes the interpretation substantially.]

4.6 Cost

[TODO: token/latency cost per protocol, framed against the detection-quality results above – this is the input to the Pareto framing in Discussion.]

5 Discussion

5.1 Safety-Cost Tradeoffs

[TODO(tiramisu): Pareto framing – across the tested protocols, what do you give up and gain at each point, rather than naming a single “best” protocol.]

5.2 Standard Clause

Clause: [TODO]

Evidence: [TODO – cite the specific result from Section 4 that justifies this clause.]

Verifiability: [TODO – per tiramisu’s point on the CSA Cloud Controls Matrix: what would a third party need to check to confirm a lab is actually complying with this clause? E.g. does the decision log show independent reviewer outputs recorded before aggregation.]

Approximate cost: [TODO – derive from the token/latency cost numbers in Results.]

6 Limitations and Dual-Use Considerations

6.1 Limitations

- **Reconstructed, not raw, incident data.** No raw logs from either organization are public. Our timeline is built from public postmortems and third-party reporting, deliberately reworded to remove hindsight framing (Section 3.1). This is a real limitation: the underlying reconstruction is one step further from ground truth than a raw log would be, and reflects the team’s own judgment about what would plausibly have been observable at each point.
- **Single incident, single replay.** One incident, replayed once per protocol (plus one sensitivity check), cannot establish a general base rate for whether reviewer diversity helps. This is a first, small test of an existing hypothesis in a new setting, not a general claim. [TODO: note actual number of repeats/seeds run, if more than one.]
- **Model and prompt dependence.** All protocols were run against one model (Qwen2.5-7B-Instruct) at one temperature setting. [TODO(Muhammad): note any other model/prompt-specific limitations – e.g. signal taxonomy coverage, context window constraints.]
- **No independent verification of ”detection”.** A model recommending `restrict` does not mean the underlying reasoning was correct, only that the recorded output matched a schema-valid category; evidence grounding (Section [X]) prevents fabricated quotations but does not verify judgment accuracy.
- **Human-escalation-timing variants and meta-agent aggregation** were scoped out of the initial implementation for time and are noted as future work, not tested results.

6.2 Dual-Use Considerations

This work characterizes how AI containment monitors succeed and fail against a real incident timeline. We do not believe this creates meaningful new uplift for causing harm: [TODO – justify this claim, e.g. we do not release any exploit code, attack technique, or information not already public in OpenAI’s and Hugging Face’s own postmortems]. A possible dual-use concern is that describing which monitor combinations most easily miss an escalating threat could inform an adversary attempting to design an attack that evades detection; we mitigate this by [TODO – e.g. not publishing exact prompts/ signal taxonomies that would let an attacker reverse-engineer detection boundaries, or by noting that our results are specific to one model and one incident and do not generalize into a general evasion recipe]. Per the submission rules, we withhold [TODO: confirm whether anything in this project counts as a ”novel installation recipe” requiring disclosure review – if unsure, ask on Discord before publishing the repo publicly].

References

- [1] OpenAI, “The Hugging Face incident and the road ahead,” 2026. <https://openai.com/index/hugging-face-incident-and-the-road-ahead/>
- [2] Hugging Face, “Anatomy of a Frontier Lab Agent Intrusion: A Technical Timeline of the July 2026 Incident,” 2026. <https://huggingface.co/blog/agent-intrusion-technical-timeline>
- [3] S. Willison, “Now we have a timeline of the OpenAI accidental attack against Hugging Face,” 2026. <https://simonwillison.net/2026/Aug/7/openai-timeline/>
- [4] S. Gallego, “Epistemic Fingerprints: False Epistemic Redundancy,” Apart Research Digital Minds Sprint, 2026. <https://sofiagallego.com/epistemic-fingerprints>
- [5] Z. Xu et al., “GuardAgent: Safeguard LLM Agents by a Guard Agent via Knowledge-Enabled Reasoning,” arXiv:2406.09187.
- [6] “Efficient LLM Safety Evaluation through Multi-Agent Debate,” arXiv:2511.06396.
- [7] “MAGE: Safeguarding LLM Agents against Long-Horizon Threats via Shadow Memory,” arXiv:2605.03228.
- [8] “Ensemble Monitoring for AI Control: Diverse Signals Outweigh More Compute,” arXiv:2605.15377.
- [9] “MI9: An Integrated Runtime Governance Framework for Agentic AI,” arXiv:2508.03858.
- [10] “Designing Multi-layered Runtime Guardrails for Foundation Model Based Agents: Swiss Cheese Model for AI Safety by Design,” arXiv:2408.02205.